

Brute Force Attack

Prerequisites

- Windows Server administration
- SSH fundamentals and public key authentication
- Incident response
- Windows security log monitoring (Event Viewer)
- Network security and firewall configuration

Problem Statement

Conduct a comprehensive security assessment and incident response for a Windows Server system running OpenSSH during a brute-force attack, focusing on analyzing Windows Security logs, verifying user accounts, and implementing SSH hardening measures

Tasks:

1. Verify network connectivity between the attacker and victim systems
2. Install and configure the OpenSSH server on the Windows target system
3. Create test user accounts and verify baseline SSH authentication
4. Simulate an SSH brute-force attack from Kali Linux
5. Investigate SSH authentication failures using Windows Security logs
6. Create and validate successful authentication events for compromise assessment
7. Implement SSH hardening and access control restrictions
8. Implement and validate certificate-based SSH authentication

Introduction

In today's cybersecurity landscape, brute-force attacks are one of the most common methods used by attackers to gain unauthorized access to systems. This project simulates a real-world attack scenario where a Windows system running an OpenSSH server is targeted by repeated login attempts.

1. Verify network connectivity between the attacker and victim systems:

Lab Environment Setup

Systems Used:

- **Target Machine:** Windows (OpenSSH Server enabled)
- **Attacker Machine:** Kali Linux
- **Network Type:** Same local network

Required Tools:

- OpenSSH Server (Windows)
- Hydra (Kali Linux)
- Event Viewer (Windows)

System Validation:

◆ Network Connectivity Test

Command used on Kali:

```
ping <Windows_IP>
```

Result:

- Successful replies were received from the Windows machine
- Confirms both systems are on the same network

```
(hunter@hunter)-[~]
$ ping 192.168.1.2
PING 192.168.1.2 (192.168.1.2) 56(84) bytes of data.
64 bytes from 192.168.1.2: icmp_seq=1 ttl=128 time=0.578 ms
64 bytes from 192.168.1.2: icmp_seq=2 ttl=128 time=0.459 ms
64 bytes from 192.168.1.2: icmp_seq=3 ttl=128 time=0.422 ms
64 bytes from 192.168.1.2: icmp_seq=4 ttl=128 time=0.523 ms
^C
— 192.168.1.2 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3063ms
rtt min/avg/max/mdev = 0.422/0.495/0.578/0.059 ms
```

2. Install and configure the OpenSSH server on the Windows target system

SSH Server Verification:

PowerShell command:

```
Get-WindowsCapability -Online | Where-Object Name -like 'OpenSSH*'
```

Result:

- OpenSSH Server was installed successfully

SSH Service Configuration:

Commands:

```
Start-Service sshd  
Set-Service -Name sshd -StartupType Automatic
```

Result:

- SSH service started and configured to run automatically

Firewall Configuration

```
New-NetFirewallRule -Name sshd -DisplayName "OpenSSH Server" -Enabled True -Direction Inbound -Protocol TCP -Action Allow -LocalPort 22
```

Result:

- Port 22 opened for SSH communication

3. Create test user accounts and verify baseline SSH authentication

Created test users:

```
net user testuser1 Password123! /add  
net user adminuser SecurePass! /add
```

Verification:

```
net user
```

Result:

- Users created successfully
- SSH login tested and working

SSH Login Test

Command from Kali:

```
ssh testuser@192.168.1.2
```

Result:

- Successful login confirmed proper SSH setup

```
Microsoft Windows [Version 10.0.26200.8246]
(c) Microsoft Corporation. All rights reserved.

testuser@DESKTOP-092NPIO C:\Users\testuser>
```

4. Simulate an SSH brute-force attack from Kali Linux

Brute-Force Attack Simulation

◆ Tool Used:

- Hydra (on Kali Linux)

◆ Command:

```
hydra -l testuser -P /usr/share/wordlists/rockyou.txt ssh://<Windows_IP>
```

◆ Observations:

- Multiple login attempts generated rapidly
- Continuous authentication failures observed
- Attack lasted approximately 3–5 minutes

```
(hunter@hunter) - [~/Downloads]
$ hydra -l testuser -P /home/hunter/Downloads/passtext -t 4 -W 3 ssh://192.168.1.2 -vv
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service orga
nizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 17:00:12
[DATA] max 4 tasks per 1 server, overall 4 tasks, 12 login tries (l:1/p:12), ~3 tries per task
[DATA] attacking ssh://192.168.1.2:22/
[VERBOSE] Resolving addresses ... [VERBOSE] resolving done
[INFO] Testing if password authentication is supported by ssh://testuser@192.168.1.2:22
[INFO] Successful, password authentication is supported by ssh://192.168.1.2:22
[22][ssh] host: 192.168.1.2 login: testuser password: Password123
[STATUS] attack finished for 192.168.1.2 (waiting for children to complete tests)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 17:00:19
```

5. Investigate SSH authentication failures using Windows Security logs

◆ Tool Used:

- Windows Event Viewer

◆ Navigation:

Event Viewer → Windows Logs → Security

◆ Failed Login Events (Event ID: 4625)

Findings:

- High number of failed login attempts
- Target account: `testuser`
- Source IP: `<Kali_IP>`
- Attack pattern: rapid repeated attempts

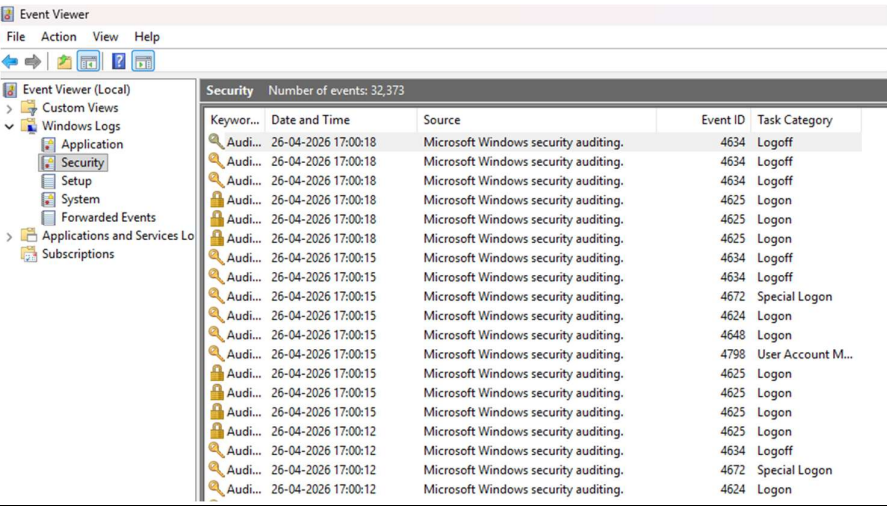
◆ Successful Login Events (Event ID: 4624)

Findings:

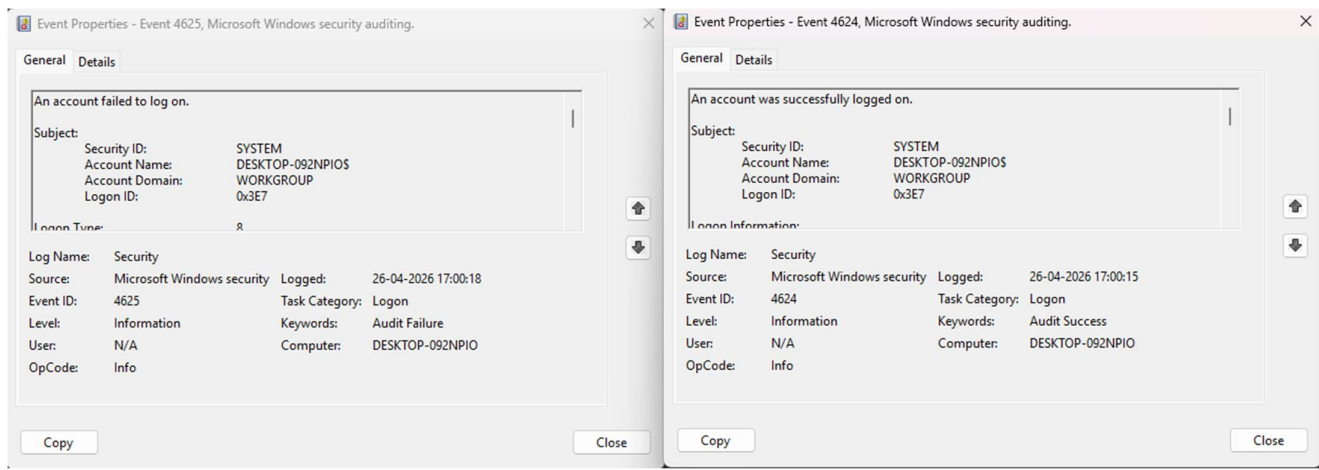
- Checked for successful logins during attack timeframe
- [Write your result here: Found / Not Found]

◆ Key Evidence Identified:

- Timestamp correlation with Hydra attack
- Repeated login failures from same IP
- Username targeting pattern



Security Number of events: 32,373				
Keywor...	Date and Time	Source	Event ID	Task Category
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:18	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4672	Special Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4624	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4648	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4798	User Account M...
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:15	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:12	Microsoft Windows security auditing.	4625	Logon
Audi...	26-04-2026 17:00:12	Microsoft Windows security auditing.	4634	Logoff
Audi...	26-04-2026 17:00:12	Microsoft Windows security auditing.	4672	Special Logon
Audi...	26-04-2026 17:00:12	Microsoft Windows security auditing.	4624	Logon



Create and validate successful authentication events for compromise assessment

Findings

- Multiple failed login attempts (Event ID 4625) were detected
- Targeted account: testuser1
- Source IP: 192.168.128.128
- Attack pattern consistent with brute-force behavior

Assessment

- Successful login events (4624) were observed
- These matched the same source IP and time window

Final Verdict

The presence of successful authentication events during the attack indicates that the system was compromised via brute-force attack.

7. Implement SSH hardening and access control restrictions

To secure SSH access by minimizing attack surface and preventing brute-force attacks.

Hardening Configuration

◆ Step 1: Edit SSH Configuration File

`C:\ProgramData\ssh\sshd_config`

◆ Step 2: Disable Password Authentication

`PasswordAuthentication no`

Prevents password-based brute-force attacks

◆ Step 3: Limit Authentication Attempts

`MaxAuthTries 3`

Restricts repeated login attempts

◆ Step 4: Restrict SSH Users

`AllowUsers adminuser`

Only authorized users allowed

◆ Step 5: Restart SSH Service

`Restart-Service sshd`

◆ Step 6: Firewall Restriction

`Set-NetFirewallRule -Name sshd -RemoteAddress 192.168.128.128`

Validation

- Unauthorized user login → Denied
- Brute-force attack → Blocked
- Reduced failed login attempts in logs

Analysis

- Attack surface significantly reduced
- Unauthorized access attempts prevented
- System hardened against brute-force attacks

Conclusion

SSH hardening successfully mitigated brute-force attack risks and enforced strict access control policies.

8. Implement and validate certificate-based SSH authentication

To implement secure authentication using SSH key pairs instead of passwords.

SSH Key Pair Generation

To implement certificate-based authentication, an SSH key pair was generated on the attacker machine using the following command:

```
ssh-keygen
```

Output Details:

- Private key stored at: /home/hunter/.ssh/id_ed25519
- Public key stored at: /home/hunter/.ssh/id_ed25519.pub

The ED25519 algorithm was used, which provides strong cryptographic security and improved performance over traditional RSA keys.

```
(hunter@hunter) - [~/Downloads]
$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/hunter/.ssh/id_ed25519):
Enter passphrase for "/home/hunter/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/hunter/.ssh/id_ed25519
Your public key has been saved in /home/hunter/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:TbQiD00fyp8gqwBwzDZ78PFqCQXP3/tLTs/MUJXxXSc hunter@hunter
The key's randomart image is:
+--[ED25519 256]--+
| . . . . E o |
| o + o . . . =+ |
| . B = . o . o o o |
| . o * + . o . + . |
| . o o . o o S . . |
| . o . o + . . . |
| . + o o . . + |
| . . . o = * |
| . . . + , = |
+---[SHA256]-----+
```

Copy Public Key:

On Kali:

```
cat ~/.ssh/id_ed25519.pub
```


Paste in Windows:

On Windows PowerShell:

```
mkdir C:\Users\adminuser\.ssh  
notepad C:\Users\adminuser\.ssh\authorized_keys
```

Fix Permissions (CRITICAL):

```
icacls C:\Users\adminuser\.ssh /inheritance:r  
icacls C:\Users\adminuser\.ssh /grant adminuser:F
```

Configure SSH :

Open:

```
notepad C:\ProgramData\ssh\sshd_config
```

Make sure:

PubkeyAuthentication yes

PasswordAuthentication no

Restart SSH

Restart-Service sshd

TEST

From Kali:

```
ssh adminuser@192.168.128.2
```

Result

Login without password

Direct access

Final Impact

“Implementation of certificate-based authentication eliminated password-based vulnerabilities and effectively prevented brute-force attacks.”